FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Report on Tallyfern Ltd's Description of its Payroll and Pensions Platform and on the Suitability of the Design and Operating Effectiveness of its Controls Relevant to Security and Availability

SOC 2 Type II Report

For the period 1 January 2025 to 31 December 2025

Prepared by Calderbrook Assurance LLP

CONFIDENTIAL. Intended solely for Tallyfern Ltd, its user entities and their auditors.

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Contents

Section I. Independent Service Auditor's Report 3

Section II. Management's Assertion 6

Section III. Description of the System 7

- Company overview and services in scope 7
- Infrastructure 8
- Software and people 9
- Data 10
- Logical access 11
- Change management 12
- Incident response, backup and recovery 13
- Risk assessment, supplier management and user entity controls 14
- Subservice organisations 15

Section IV. Trust Services Criteria, Controls, Tests and Results 16

Section V. Other Information Provided by Management 24

Glossary 25

Section I. Independent Service Auditor's Report

To the Board of Directors of Tallyfern Ltd.

Scope. We have examined the accompanying description of the Payroll and Pensions Platform (the description) for the period 1 January 2025 to 31 December 2025, and the suitability of the design and operating effectiveness of controls stated in the description to provide reasonable assurance that the service commitments and system requirements were achieved based on the trust services criteria relevant to security and availability.

The description covers the Tallyfern Payroll and Tallyfern Pensions services only. The Tallyfern HR Records module is not included in the description and was not within the scope of our examination.

Tallyfern Ltd uses Amazon Web Services (AWS) as a subservice organisation for infrastructure hosting. The description includes only the controls of Tallyfern and excludes the controls of AWS (the carve-out method). Our examination did not extend to controls of AWS.

Section I. Independent Service Auditor's Report (continued)

Service organisation's responsibilities. Tallyfern is responsible for its service commitments and system requirements, for designing, implementing and operating effective controls, and for preparing the description and its assertion.

Service auditor's responsibilities. Our responsibility is to express an opinion based on our examination. We conducted our examination in accordance with attestation standards established for service organisation reports. Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls were suitably designed and operating effectively.

An examination involves performing procedures to obtain evidence, assessing the risks that the description is not fairly presented, and testing the operating effectiveness of those controls. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

Inherent limitations. Because of their nature, controls may not always operate effectively. Projections of any evaluation of effectiveness to future periods are subject to the risk that controls may become inadequate.

Section I. Independent Service Auditor's Report (continued)

Description of tests of controls. The specific controls we tested and the nature, timing and results of those tests are presented in Section IV.

Opinion. In our opinion, in all material respects, the description presents the Payroll and Pensions Platform that was designed and implemented throughout the period 1 January 2025 to 31 December 2025, the controls stated in the description were suitably designed, and the controls operated effectively to provide reasonable assurance that the service commitments and system requirements were achieved.

Deviations. Section IV identifies exceptions in controls CC6.1 and CC6.2. These exceptions did not, in our judgement, prevent the achievement of the related criteria, and have not resulted in a modification of our opinion. User entities should consider them in their own assessments.

Calderbrook Assurance LLP

London, 27 February 2026

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Section II. Management's Assertion

We have prepared the accompanying description of Tallyfern Ltd's Payroll and Pensions Platform for the period 1 January 2025 to 31 December 2025, based on the description criteria for a description of a service organisation's system.

We confirm, to the best of our knowledge and belief, that the description presents the system that was designed and implemented throughout the period, that the controls stated in the description were suitably designed, and that the controls operated effectively throughout the period to achieve the service commitments and system requirements based on the applicable trust services criteria.

The Tallyfern HR Records module, launched in September 2025, is outside the boundaries of the system described in this report.

Signed on behalf of Tallyfern Ltd: Chief Executive Officer; Head of Security and IT.

Section III. Description of the System: Company Overview and Services in Scope

Tallyfern Ltd is a private limited company registered in England and Wales, founded in 2019 and headquartered in London. Tallyfern provides payroll and pensions software to UK employers with 20 to 500 staff.

Services in scope. Tallyfern Payroll: monthly and weekly payroll runs, HMRC Real Time Information (RTI) submissions and electronic payslips. Tallyfern Pensions: workplace pension auto-enrolment assessments and contribution files for pension providers.

Services not in scope. Tallyfern HR Records, which stores employee contracts, absence and right-to-work documents, is offered to customers as a separate module. It runs on separate infrastructure and is not included in this description or in the auditor's examination.

Service commitments include availability of 99.5% per calendar month for the in-scope services, encryption of customer data, and notification of security incidents affecting customer data as set out in customer contracts.

Section III. Infrastructure

The in-scope services are hosted on Amazon Web Services in the London region (eu-west-2) across three availability zones. Production workloads run in containers on managed compute services. Customer data is stored in managed PostgreSQL databases and object storage.

All customer data at rest is encrypted with AES-256 using keys held in the AWS key management service. Keys are rotated annually. Data in transit over public networks is encrypted with TLS 1.2 or higher.

Production, staging and development environments are separated into distinct AWS accounts. Network access to production databases is restricted to application services within private subnets.

Public web applications are served through a managed load balancer with a web application firewall.

Section III. Software and People

Software. Tallyfern's applications are developed in-house. Source code is held in a managed version control service. Third-party libraries are tracked through automated dependency monitoring.

People. At 31 December 2025 Tallyfern had 42 employees. Security and IT is led by the Head of Security and IT, who reports to the Chief Executive Officer, supported by two security engineers. A customer support team of six uses the Tallyfern Admin support console to assist customers.

Roles and responsibilities for security are documented in the Information Security Policy, which is approved by the board annually.

Section III. Data

Customer data processed by the in-scope services includes employee names, addresses, National Insurance numbers, bank account details, salary and pension contribution data.

Data is classified as Confidential under Tallyfern's data classification policy. Access to customer data is limited to personnel who require it for their role.

Customer data is retained for the duration of the customer contract and as required by statutory payroll record keeping obligations. Data retention and deletion at contract end are governed by customer contracts and are not addressed by the controls in this report.

Section III. Logical Access

All staff authenticate to internal systems through single sign-on via a central identity provider. Accounts are created on the basis of an approved request from a line manager.

Multi-factor authentication is required by the identity provider for access to the AWS production accounts and the version control service.

The Tallyfern Admin support console allows support staff to view and amend customer configuration. Administrative roles in the console are granted on approval by the Head of Customer Support.

User access reviews of in-scope systems are designed to be performed quarterly by system owners, with results recorded in the ticketing system. Leavers' access is revoked through the identity provider on the last working day, triggered by the HR system.

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Section III. Change Management

Changes to production code follow a documented software development life cycle. Each change is raised as a pull request, peer reviewed by an engineer other than the author, and must pass automated tests before merge.

Deployment to production is automated through a pipeline that only deploys reviewed code from the main branch. Emergency changes are approved by the Head of Engineering and reviewed retrospectively within two business days.

Infrastructure changes are made through version-controlled configuration and follow the same review process.

Section III. Incident Response, Backup and Recovery

Incident response. Tallyfern maintains a documented incident response plan that defines severity levels, roles and communication. The plan is tested annually through a tabletop exercise.

Backups. Production databases are backed up daily using automated encrypted snapshots, retained for 35 days. Restores from backup are tested quarterly to confirm that data can be recovered.

Disaster recovery. A disaster recovery plan describes the recovery of the in-scope services in an alternative availability zone. The plan is tested annually.

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Section III. Risk Assessment, Supplier Management and User Entity Controls

Risk assessment. A formal risk assessment is performed annually and reviewed by the board. Risks are recorded in a risk register with owners and treatment plans.

Supplier management. Suppliers that process customer data or support the in-scope services are classified as critical and are risk assessed annually.

Complementary user entity controls. User entities are responsible for: managing their own users' access to the Tallyfern applications; enabling multi-factor authentication for their own user accounts; reviewing payroll outputs before approval; and notifying Tallyfern promptly of suspected security incidents.

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Section III. Subservice Organisations

Tallyfern uses Amazon Web Services as its only subservice organisation for the in-scope services. AWS provides physical data centre security, environmental controls and the underlying infrastructure.

Complementary subservice organisation controls expected of AWS include physical access restrictions to data centres, protection of infrastructure against environmental threats, and the availability of the underlying compute, storage and network services.

Tallyfern monitors AWS through annual review of AWS's own SOC 2 report.

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Section IV. Trust Services Criteria, Controls, Tests and Results

This section presents the controls tested, the tests performed by the service auditor and the results.

Tests performed included inquiry of appropriate personnel, observation of the application of controls, inspection of documents and records, and re-performance of controls. Where a control operates many times a year, samples were selected in line with the service auditor's sampling methodology.

Where a test identified an exception, the result describes the exception. Management's responses to exceptions are presented in Section V and have not been subject to examination.

Section IV. Control Environment and Communication (CC1, CC2)

ID	Control activity	Test performed	Result
CC1.1	The board approves the Information Security Policy annually.	Inspected board minutes for approval.	No exceptions noted.
CC1.4	New employees are background screened before their start date.	Inspected screening records for a sample of 10 new joiners.	No exceptions noted.
CC1.5	Employees complete security awareness training annually.	Inspected training records for a sample of 25 employees.	No exceptions noted.
CC2.2	Security policies are published to all staff on the intranet.	Observed the intranet policy page.	No exceptions noted.

Section IV. Risk Assessment and Monitoring (CC3, CC4, CC5)

ID	Control activity	Test performed	Result
CC3.1	A formal risk assessment is performed annually and reviewed by the board.	Inspected the 2025 risk assessment and board minutes.	No exceptions noted.
CC4.1	An independent third party performs an annual penetration test of the in-scope applications.	Inspected the 2025 penetration test report and remediation tickets.	No exceptions noted.
CC4.2	High and critical penetration test findings are remediated within 30 days.	Inspected remediation tickets for all high findings.	No exceptions noted.
CC5.2	Security controls are documented in policies reviewed annually.	Inspected policy review records.	No exceptions noted.

Section IV. Logical Access (CC6.1)

ID	Control activity	Test performed	Result
CC6.1a	Staff authenticate to internal systems through single sign-on via the identity provider.	Inspected identity provider configuration.	No exceptions noted.
CC6.1b	Multi-factor authentication is enforced for all administrative access to production systems and the Tallyfern Admin support console.	Inspected identity provider policy and MFA status for a sample of 25 accounts with administrative access.	**Exception noted. For 3 of 25 sampled accounts with administrative access to the Tallyfern Admin support console, MFA was not enforced. The accounts belonged to support staff and had been excluded from the MFA policy group.**
CC6.1c	Customer data at rest is encrypted using AES-256.	Inspected database and storage encryption settings.	No exceptions noted.

Section IV. Logical Access (CC6.2, CC6.3)

ID	Control activity	Test performed	Result
CC6.2a	User access to in-scope systems is reviewed quarterly by system owners.	Inspected access review records for each quarter of the period.	**Exception noted. Access reviews were performed for Q1, Q3 and Q4. No access review was performed for Q2 2025.**
CC6.2b	New access is granted on approval by the line manager.	Inspected approvals for a sample of 25 access requests.	No exceptions noted.
CC6.3	Leavers' access is revoked within one business day of termination.	Compared HR leaver dates with identity provider deactivation for a sample of 15 leavers.	No exceptions noted.

Section IV. Network, Encryption and Malware (CC6.6, CC6.7, CC6.8)

ID	Control activity	Test performed	Result
CC6.6	Production databases are accessible only from private subnets.	Inspected network configuration.	No exceptions noted.
CC6.7	Data in transit over public networks is encrypted with TLS 1.2 or higher.	Inspected load balancer TLS policy.	No exceptions noted.
CC6.8	Endpoint protection is installed on all company laptops.	Inspected device management reports for a sample of 25 devices.	No exceptions noted.

Section IV. System Operations (CC7)

ID	Control activity	Test performed	Result
CC7.1	Authenticated vulnerability scans of production systems are run monthly and critical findings are tracked to remediation.	Inspected scan reports for a sample of 4 months.	No exceptions noted.
CC7.2	Security logs are centralised and retained for 12 months.	Inspected log platform configuration and retention settings.	No exceptions noted.
CC7.3	Alerts for security events are routed to an on-call engineer.	Inspected alert routing configuration.	No exceptions noted.
CC7.4	The incident response plan is tested annually through a tabletop exercise.	Inspected the 2025 tabletop exercise report.	No exceptions noted.

FICTIONAL SAMPLE created for a software demonstration. Tallyfern and Calderbrook Assurance LLP do not exist. Not a real SOC 2 report.

Section IV. Change Management, Supplier Risk and Availability (CC8, CC9, A1)

ID	Control activity	Test performed	Result
CC8.1	Production changes are peer reviewed and approved before release.	Inspected pull requests for a sample of 25 production changes.	No exceptions noted.
CC9.2	Critical suppliers are risk assessed annually.	Inspected supplier assessments for all critical suppliers.	No exceptions noted.
A1.2	Production databases are backed up daily and restores are tested quarterly.	Inspected backup configuration and quarterly restore test records.	No exceptions noted.
A1.3	The disaster recovery plan is tested annually.	Inspected the 2025 disaster recovery test report.	No exceptions noted.

Section V. Other Information Provided by Management

The information in this section is presented by Tallyfern management to provide additional information and is not part of the system description. It has not been subject to the procedures applied in the examination.

Response to CC6.1b. The three support accounts were added to the MFA policy group on 14 March 2026. Tallyfern has added an automated daily check that alerts if any administrative account is outside the MFA policy group.

Response to CC6.2a. The Q2 2025 access review was missed during a change of system owner. The review was completed retrospectively in August 2025 and no inappropriate access was identified. Reviews are now scheduled in the ticketing system with escalation to the Head of Security and IT.

Glossary

Carve-out method: the subservice organisation's controls are excluded from the description and from the scope of the examination.

Complementary user entity controls: controls that user entities are expected to operate for the trust services criteria to be met.

Exception: an instance in which a control did not operate as described during the period.

SOC 2 Type II: a report on the fairness of a system description and the design and operating effectiveness of controls over a period of time.